

Cyber Threat Intelligence

Executive Briefing

Report Date: July 04, 2026

Generated: 2026-07-04 17:34 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	8	6	1	20

2. Executive Summary

As of July 04, 2026, the security operations center has concluded analysis on 20 distinct vulnerabilities, categorized by severity as 5 Critical, 8 High, 6 Medium, and 1 Low. The current organizational risk posture is elevated, characterized as High based on CVSS v3.1 impact assessments regarding unauthenticated access and remote code execution potential. The primary threat is identified as CVE-2026-52830, Bearer Token Path Traversal in fast-mcp-telegram, which warrants immediate prioritization due to the ease of exploitation in accessing restricted system paths. Consequently, our recommended response posture is immediate remediation and temporary isolation of affected network segments to prevent potential unauthorized data exfiltration. IT and security teams are directed to execute the following mitigation schedule to reduce our attack surface to an acceptable threshold.

3. Critical Action List

- Immediate patching of CVE-2026-52830 in fast-mcp-telegram within 12 hours to mitigate path traversal risks.
- Disable unauthorized DuckDB interface access via Recce Server (CVE-2026-49360) within 24 hours.
- Rotate and reconfigure hardcoded JWT secrets in 9router (CVE-2026-49352) within 24 hours.
- Implement sanitization filters for the LaunchServer FileServerHandler (CVE-2026-54617) within 24 hours.
- Enforce strict Host header validation in Steeltoe (CVE-2026-50194) to prevent port bypass within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-52830	Bearer Token Path Traversal in fa...	9.8	Critical	95/100	CWE-22
CVE-2026-49360	Unauthenticated SQL Injection in ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Authentication Bypass via Default...	9.8	Critical	88/100	CWE-798

CVE-2026-54617	Path Traversal in LaunchServer Ha...	9.8	Critical	88/100	CWE-22
CVE-2026-50194	Management Port Bypass in Steeltoe	9.1	Critical	84/100	CWE-288
CVE-2026-2092	Improper Validation of SAML Asser...	8.1	High	79/100	CWE-1287
CVE-2026-46599	Resource Exhaustion in golang.org...	7.5	High	78/100	CWE-770
CVE-2026-50200	Database Credential Leakage in St...	6.5	Medium	78/100	CWE-200
CVE-2026-50196	Eureka Registry Poisoning in Stee...	7.5	High	78/100	CWE-20
CVE-2026-50201	Unauthorized Access to Steeltoe A...	6.5	Medium	69/100	CWE-269
CVE-2026-49353	Host Header Injection in 9router ...	7.5	High	68/100	CWE-290
CVE-2026-52792	Source Code Disclosure in Algerno...	7.5	High	68/100	CWE-69
CVE-2026-49289	Denial of Service via XPath in Si...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Corruption in Zebra Addre...	7.5	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow in jxl-grid 32-b...	8.6	High	66/100	CWE-122
CVE-2026-49284	Insecure SAML Assertion Processin...	6.8	Medium	64/100	CWE-345
CVE-2026-50202	JWKS Cache Sharing Vulnerability ...	5.6	Medium	63/100	CWE-668
CVE-2026-50267	Insecure Storage of TLS Keys in S...	5.5	Medium	42/100	CWE-312
CVE-2026-49292	Unauthorized Access to Kiwi TCMS ...	4.8	Medium	28/100	CWE-862
CVE-2026-50268	Insecure OAEP Padding Default in ...	2.2	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-52830

Finding: Bearer Token Path Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 95/100 | CWE: CWE-22

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1552, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The fast-mcp-telegram implementation allows path traversal via manipulation of Bearer tokens. The vulnerability allows an attacker to bypass reserved session protection mechanisms by traversing into forbidden filesystem directories. This leads to complete access to sensitive Telegram session files and internal credentials.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an API request to fast-mcp-telegram containing a crafted Bearer token with '../' sequences. The application logic fails to validate the token path and treats it as a file reference within the sensitive Telegram session storage directory. The attacker successfully reads internal session data to impersonate the user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

CVE-2026-49360

Finding: Unauthenticated SQL Injection in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server fails to authenticate requests, allowing arbitrary SQL execution through the DuckDB interface. This vulnerability stems from improper validation of input parameters before passing them to the underlying query engine. An unauthenticated remote attacker can leverage this to gain full read and write access to the filesystem.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a crafted malicious query to the Recce server endpoint. The server interface routes this input directly to DuckDB without checking for unauthorized file system operation flags. The engine executes the command, granting the attacker the ability to read sensitive local files or overwrite configuration data on the host.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>

CVE-2026-49352

Finding: Authentication Bypass via Default JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application utilizes a hardcoded fallback JWT secret for authentication. An attacker can use this known, static secret to sign arbitrary tokens, effectively bypassing all authentication controls. This leads to complete administrative takeover of the application for any unauthenticated remote user.

Proof of Concept (PoC):

An unauthenticated remote attacker retrieves the hardcoded JWT secret from the public source repository or binary. The attacker then generates a JWT claim with administrative identity and signs it using the leaked secret key. By submitting this token in the Authorization header, the attacker successfully gains full session privileges.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1083, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The LaunchServer FileServerHandler contains an unauthenticated path traversal vulnerability. By providing specially crafted file paths, an attacker can escape the designated directory and access sensitive files on the host system. This results in unauthorized disclosure of system files and credentials.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the FileServerHandler endpoint with a path parameter containing '..//' sequences. The application improperly sanitizes the path and resolves it to a location outside the restricted base directory. This allows the attacker to download sensitive files, such as /etc/passwd.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>

CVE-2026-50194

Finding: Management Port Bypass in Steeltoe

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 84/100 | CWE: CWE-288

Score Provenance: CNA Official - Vector Recalculated
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe is vulnerable to a management-port isolation bypass via Host header spoofing. The application relies on the

Host header to enforce separation between internal management traffic and external requests. By forging this header, an attacker can access sensitive management endpoints normally exposed only on internal network interfaces.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the Steeltoe application and submits a request with a spoofed 'Host' header matching the internal management address. The framework bypasses its isolation checks and allows access to the management-port endpoints. The attacker gains the ability to execute administrative actions intended for internal use only.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

CVE-2026-2092

Finding: Improper Validation of SAML Assertions in Keycloak

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 79/100 | CWE: CWE-1287

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Keycloak fails to properly validate encrypted SAML assertions, leading to potential unauthorized access. The vulnerability arises from an oversight in the cryptographic assertion verification logic, which can be bypassed under specific conditions. Attackers may exploit this to assume the identity of other users within the environment.

Proof of Concept (PoC):

An authenticated user with low privileges intercepts a SAML response intended for another session. By modifying parts of the encrypted assertion that bypass the weak cryptographic checks, the user resubmits the assertion to Keycloak. The server erroneously validates the forged assertion, granting the attacker the identity and privileges of the target user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>

CVE-2026-46599

Finding: Resource Exhaustion in golang.org/x/image/tiff

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None

Integrity Impact

None

Availability Impact

High

Description:

The PackBits decompression function in `golang.org/x/image/tiff` is susceptible to excessive resource consumption. The lack of adequate bounds checking during the decompression of malformed TIFF images causes the process to consume unbounded amounts of memory. This leads to a denial-of-service condition when processing untrusted image data.

Proof of Concept (PoC):

An attacker transmits a specially crafted TIFF image file containing a maliciously inflated PackBits compression sequence. The application calls the vulnerable decompression function, which enters an infinite allocation loop while attempting to interpret the invalid header. This results in an immediate crash of the application service due to memory exhaustion.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

CVE-2026-50200**Finding: Database Credential Leakage in Steeltoe Actuators**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 78/100 | CWE: CWE-200

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The environment actuator in Steeltoe fails to correctly sanitize connection strings, leading to the accidental exposure of embedded database passwords. The sanitizer logic omits certain property patterns, resulting in cleartext credentials appearing in management responses. This significantly compromises the confidentiality of backend systems.

Proof of Concept (PoC):

An authenticated user requests the `/env` management endpoint in the Steeltoe framework. The framework returns the full list of system environment variables and properties. The attacker identifies unmasked database connection strings in the output, obtaining administrative access to the backend database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

CVE-2026-50196**Finding: Eureka Registry Poisoning in Steeltoe**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-20

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Steeltoe Discovery Eureka client is vulnerable to registry poisoning via unrecognized DataCenterInfo.Name values. The client incorrectly processes these values, potentially allowing an attacker to overwrite registry entries for existing services. This disruption can lead to service redirection and potential traffic interception.

Proof of Concept (PoC):

An attacker with access to the network registers a malicious service with a crafted DataCenterInfo.Name attribute against the Eureka registry used by Steeltoe. The Steeltoe client fetches this update and trusts the malicious metadata. Subsequent service discovery requests are redirected to the attacker's endpoint instead of the intended service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>

CVE-2026-50201

Finding: Unauthorized Access to Steeltoe Actuators

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-269

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1068, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe framework improperly restricts sensitive management actuators like heapdump and environment endpoints. These endpoints require only a lower-level 'Restricted' permission rather than administrative authorization. Consequently, low-privilege users can exfiltrate runtime data or configuration secrets.

Proof of Concept (PoC):

A user with restricted privileges authenticates to the Steeltoe management interface. The user requests the /heapdump endpoint, which the framework grants because the permission check is insufficient. The user downloads the heap dump, revealing sensitive information such as memory-resident user passwords and database connection strings.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>

CVE-2026-49353

Finding: Host Header Injection in 9router Access Gate

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router application exhibits an incomplete fix for a local-only access gate bypass vulnerability. By manipulating the HTTP Host header, an attacker can deceive the application into accepting requests intended only for internal interfaces. This allows unauthorized access to restricted endpoints from external network segments.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates a request to the 9router public interface. The attacker injects a spoofed Host header pointing to a trusted internal loopback address. The application fails to validate the header integrity, granting the request bypass to the administrative gate and exposing internal documentation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>

CVE-2026-52792

Finding: Source Code Disclosure in Algernon via NTFS

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server reveals server-side script sources when queried with specific NTFS filenames on Windows systems. The application fails to handle legacy NTFS alternate data streams or specific filename conventions during file access requests. This permits unauthenticated remote attackers to retrieve and read sensitive application source code.

Proof of Concept (PoC):

An unauthenticated remote attacker requests a known script file (e.g., app.lua) appended with specific NTFS delimiters like '::DATA'. The server-side handling fails to process the request as a script execution and instead returns the raw contents of the file. The attacker receives the full source code, potentially revealing embedded API keys.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>

CVE-2026-49289

Finding: Denial of Service via XPath in SimpleSAMLphp

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service vulnerability involving XPath transformations. By submitting an overly complex or nested XPath expression, an attacker can exhaust server CPU resources. This results in the inability of the service to process legitimate SAML assertions, halting authentication flows.

Proof of Concept (PoC):

An attacker sends a malicious SAML request containing an optimized but computationally expensive XPath query to the SimpleSAMLphp assertion consumer service. The server processes the request and stalls indefinitely while evaluating the complex XPath transform. This effectively blocks other users from authenticating to the service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Corruption in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book service experiences memory pool corruption due to improper handling of IPv4-mapped address structures. The vulnerability arises from an incorrect boundary calculation when transitioning between address family types. This leads to an aborted process state and potential service disruption.

Proof of Concept (PoC):

An attacker sends a specially formatted network packet targeting the Zebra Address Book interface containing an IPv4-mapped address field that triggers a miscalculation in the memory pool management. The service detects the inconsistency and executes an assertion failure, immediately aborting the process. This causes a permanent denial of

service for all address book lookups.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>

CVE-2026-52834

Finding: Integer Overflow in jxl-grid 32-bit

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library exhibits an out-of-bounds write vulnerability on 32-bit platforms due to integer overflow during memory allocation. An attacker providing a maliciously sized image or data structure can trigger a heap-based buffer overflow. This may result in arbitrary code execution or process crashes.

Proof of Concept (PoC):

An attacker provides an input image with extremely large dimensions that cause an integer overflow during calculation of the required grid buffer size. The application allocates insufficient memory for the operation. Subsequent writing to the grid buffer results in memory corruption, potentially leading to controlled remote code execution.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

CVE-2026-49284

Finding: Insecure SAML Assertion Processing in SimpleSAMLphp

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp Service Provider incorrectly accepts SAML responses when an unsigned InResponseTo field is paired with a signed assertion lacking specific SubjectConfirmationData checks. This allows for potential IdP spoofing where an attacker can supply assertions from a malicious source. The failure stems from inadequate correlation of

SAML messages and assertions.

Proof of Concept (PoC):

An attacker intercepts a login flow and substitutes a legitimate SAML assertion with one signed by their own malicious IdP. They supply an unsigned InResponseTo field to bypass existing validation logic. The SimpleSAMLphp component erroneously trusts the assertion, granting the attacker access to the victim's session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

CVE-2026-50202

Finding: JWKS Cache Sharing Vulnerability in Steeltoe

CVSS v3.1 Score: 5.6 | Severity: Medium | Urgency Score: 63/100 | CWE: CWE-668

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The Steeltoe framework maintains a static JSON Web Key Set (JWKS) cache that is improperly shared across different security schemes and is never invalidated. This behavior may lead to cross-scheme key leakage if multiple security contexts are involved. The cache persistence exposes applications to stale or incorrect key trust scenarios.

Proof of Concept (PoC):

An attacker with control over an external JWKS endpoint waits for the Steeltoe application to fetch the key. Due to the lack of invalidation, the attacker updates their key set, but the application continues to use the old key, or vice-versa, causing inconsistency. The attacker exploits this cached state to perform unauthorized authentication.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>

CVE-2026-50267

Finding: Insecure Storage of TLS Keys in Steeltoe

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to properly secure TLS private keys, writing them to the /tmp directory with default filesystem permissions and failing to delete them after use. This exposes the keys to any local user on the system. The lack of proper cleanup and restrictive permission setting constitutes a significant confidentiality vulnerability.

Proof of Concept (PoC):

A local attacker with low-level privileges monitors the /tmp directory during the Steeltoe application startup sequence. The attacker reads the sensitive TLS private key file before the application can clear it. The attacker can then use this stolen key to perform man-in-the-middle attacks on the application's traffic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

CVE-2026-49292

Finding: Unauthorized Access to Kiwi TCMS Database Init

CVSS v3.1 Score: 4.8 | Severity: Medium | Urgency Score: 28/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The /init-db/ page in Kiwi TCMS remains responsive and accessible even after the initial application deployment. This failure to disable the setup functionality allows potential access to sensitive database configuration routines. An attacker could theoretically trigger state-changing operations on the database after the intended first use.

Proof of Concept (PoC):

An attacker navigates to the /init-db/ endpoint on a production instance of Kiwi TCMS. The application fails to check for an existing database flag and renders the initialization form. The attacker submits configuration parameters that reset or modify database state, disrupting existing service operations.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

CVE-2026-50268

Finding: Insecure OAEP Padding Default in Steeltoe

CVSS v3.1 Score: 2.2 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official - Vector Recalculated
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	High

Attack Complexity	High
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe framework incorrectly falls back to the deprecated PKCS#1 v1.5 padding scheme even when OAEP is explicitly configured. This silently reduces the cryptographic strength of the encryption process against certain oracle attacks. The mismatch between intent and configuration leaves encrypted data vulnerable to potential decryption.

Proof of Concept (PoC):

A privileged attacker monitors the TLS handshakes where Steeltoe is configured. The attacker identifies that the server is using PKCS#1 v1.5 despite the OAEP policy configuration. By launching a Bleichenbacher-style attack, the attacker recovers small amounts of sensitive data from the encrypted communications.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>